

PLATFORM & BUSINESS AUDIT · SEPTEMBER 2026

Kozy Care Audit Report

A full examination of the kozycare.ng platform after the phase-70 release: the Shoe Club launch, branch numbers reset, rider web-push activation, security posture, production operations, and the commercial position against the Lagos market — closing with a ranked action list and a 30-60-90 plan.

PREPARED FOR

Chigozie Ubah · Founder, Kozy Care

DATE

28 September 2026 · Lagos, Nigeria

KOZYCARE.NG · UNCOMPROMISING CARE

PHASE 70 RELEASE

Table of Contents

1 Executive Summary	2
2 Scope and Method	2
3 Platform Health	3
4 Security and Compliance	4
5 Reliability and Operations	4
6 Customer Experience	5
7 Commercial and Business Audit	5
8 Data and Analytics	6
9 Prioritized Recommendations	7
10 The 30-60-90 View	7

1 Executive Summary

This audit examined the Kozy Care platform end to end on 28 September 2026, immediately after the phase-70 release shipped to production. It covers the codebase (79 API routes, 29 database models, the customer site, admin console and rider app), the production environment on Vercel and Supabase, the operating procedures that have accumulated across 70 build phases, and the commercial position of the business in Lagos. The overall verdict is that the platform is in unusually good shape for its stage: the architecture is coherent, the security posture is above average for a small-team SaaS, and the operational tooling (branch health, payment verification, rider dispatch, marketing automation) is ahead of what most competitors in this market run on. The binding constraint is no longer software. It is demand generation and a small number of production-hardening items that should be closed before volume grows.

Three events during this audit window materially changed the risk picture, all in the right direction. First, the VAPID keys for rider web-push notifications, which had been pending since phase 61, are now configured in production and verified live; stop notifications now reach riders without the dashboard being open. Second, the previously lost source of the phase-69 release (rider auto-dispatch and branch ownership) was recovered from the live deployment and reconciled into the repository, eliminating a silent rollback risk. Third, the standalone Shoe Club subscription and the company-branch numbers reset shipped and were verified live with an eleven-point production check. The remaining findings are graded in the table below and expanded through the report.

Area	Score	Assessment
Platform architecture	9 / 10	Modern single Next.js 16 monolith, 29 indexed Prisma models, graceful degradation on every integration
Security	7.5 / 10	Strong auth, RBAC, webhook signatures and CSP; rate limiting falls back per-instance because Redis is unset
Reliability and ops	7 / 10	Proven deploy recipe and self-healing seeds; schema-by-push and no verified backups need attention
Customer experience	8.5 / 10	Two-minute guest booking, plain-language plans, live tracking; notification depth still email-only
Commercial engine	8 / 10	Plans, club, coupons and automation are built and priced to undercut; zero subscribers means sales is the gap
Data and analytics	7 / 10	Branch attribution, response-time audit and epoch resets are live; reconciliation and backups are manual

The single most important message of this audit: the product has outrun distribution. The membership engine has processed real orders and every renewal path is wired, yet the subscriber count on production remains zero, and the new Shoe Club will not sell itself. The 30-60-90 plan in the final chapter therefore weights sales motions above new features, with just enough hardening work to keep growth safe.

2 Scope and Method

The audit combined static review of the repository at commit 61927bc with live probing of the production deployment that serves kozycare.ng, the Vercel project environment, and the production database schema and plan catalogue (read-only inspection and one idempotent migration that created the Shoe Club rows). Where the worklog records prior incidents, such as the newsletter timing drift or the rider notification gap, the fixes were re-verified rather than assumed. Browser-level checks against production confirmed the public plans surface, the Shoe Club section, and the rider push key endpoint. Nothing in this audit required destructive access: the branch numbers reset introduced in phase 70 was exercised against a local copy of the database, and production data was only read.

Grading follows a simple convention. Findings marked P0 are things that could hurt the business within weeks if ignored, P1 within a quarter, and P2 are quality-of-life improvements worth scheduling when convenient. Scores in the executive table are relative to what a well-run early-stage laundry operation in Lagos should reasonably expect from its software, not relative to a venture-funded engineering org.

3 Platform Health

Architecture and code quality

The application is a single Next.js 16.1.1 App Router project on React 19 with Prisma 6.11 against Supabase Postgres, deployed as serverless functions on Vercel. This remains the right shape for the business: one deployable, one database, no service-to-service chatter to debug, and a build that completes in about a minute. The codebase shows real discipline for its size. TypeScript is strict with build errors deliberately not suppressed in the Next config; ESLint gates the same standard; a repository-wide search found zero TODO or FIXME markers; and only a dozen diagnostic console.log calls remain across the source tree. Every integration, from Brevo email to Paystack to web-push, degrades gracefully when its key is absent, which is why the site kept serving through every credential incident in the worklog.

Data modelling is similarly tidy. The schema has 29 models with 60 explicit indexes, and lookup-heavy paths (orders by status and date, payments by order, push subscriptions by user) are covered. The self-seeding pattern used for app settings, the price catalogue, branches and subscription plans continues to pay off: a fresh database bootstraps itself into a working state with no manual seed step, which is exactly what saved this session after the sandbox reset.

Phase-70 additions verified this session

- Shoe Club: a second subscription family (SHOES) sold from the shoe-care section, with one-membership-per-family semantics, club-first shoe pickup routing, and an admin editor separate from the laundry tiers. Verified with 25 local assertions and 11 production checks.
- Branch numbers reset: an epoch field (statsResetAt) on company branches with a two-tap reset on the Branch Health card. Orders and payments are never deleted; the all-time line simply counts from the epoch, and franchise branches are refused server-side.
- Booking wizard scroll behaviour: every step transition now returns the customer to the top of the page (measured 2419 to 0 pixels in the verification battery).

- Rider web-push: the owner-pasted VAPID keys were confirmed live on production (available: true), closing a phase-61 action item.

4 Security and Compliance

Authentication is NextAuth with server-side sessions and bcrypt password hashing, and the console roles are policed twice: in middleware for pages and inside each API route via a `requireRole` guard. Fifty-seven of the seventy-nine route files carry explicit session checks, and the remaining ones are deliberately public (plan listings, health probes, tracking pixels). The staff lifecycle deserves particular praise: paused or revoked staff cannot obtain a session even with a correct password, and their audit trails are retained. The Paystack webhook verifies the `x-paystack-signature` HMAC before trusting any charge event, and card activation is idempotent through a unique reference per subscription.

Transport and browser hardening are configured at the Next.js layer: HSTS, X-Frame-Options DENY, a strict referrer policy, a permissions policy that only grants camera and geolocation to the app itself, and a content-security-policy that allowlists only the domains the app actually talks to. Secrets live exclusively in Vercel environment storage, GitHub push protection has caught leaks before they landed, and the repository carries no credential material.

Findings

- P1 — rate limiting is per-instance in production. The Upstash Redis environment variables are present but empty, so the limiter silently falls back to in-memory counters inside each serverless instance. Booking and signup caps therefore hold per warm Lambda rather than globally. A free Upstash database and two environment values close this gap.
- P2 — a handful of public marketing endpoints (open and click trackers) accept unauthenticated writes with no rate limit. They are low-risk today because each write is a tiny row, but they should join the limiter before any high-volume campaign.
- P2 — there is no automated vulnerability scanning of dependencies. The stack is current (Next 16, React 19, Prisma 6), and a weekly audit run would keep it that way.

5 Reliability and Operations

Deployment pipeline

The deploy recipe is now stable and documented in the README: commit to main, then ship source through the Vercel CLI or REST API with the project-scoped token, which cannot be validated with whoami but deploys correctly. This session shipped the phase-70 build in about one minute, aliased automatically to `kozycare.ng`, and applied the schema through the build itself. The historical footguns (dead tokens, missing project link, lost sandbox state) each have a written recovery path in the worklog, and the README now encodes them for the next operator.

Findings

- P1 — schema changes ship via `prisma db push --accept-data-loss` inside the build command. This has been convenient for seventy phases, but on a production database holding real payment records it is one

misunderstood column away from an irreversible drop. Adopting Prisma migrate with reviewable migration files is a one-off switch.

- P1 — backups are assumed, not verified. Supabase makes automated backups available, but no restore has ever been rehearsed and no retention policy is written down. A monthly restore rehearsal into a scratch database converts this from a hope into a control.
- P2 — there is no staging environment. Every change lands in production, and local testing depends on the developer sandbox surviving. A Vercel preview deployment with a branched database would let risky work (pricing engine, webhook changes) be rehearsed first.
- P2 — error monitoring is not wired. SENTRY_DSN is empty, so runtime errors surface only when a customer complains. Even the free tier of an error tracker would change that.

6 Customer Experience

The booking path remains the strongest surface: a guest can complete an order in roughly two minutes without an account, with an auto-saved draft, offer codes validated live server-side, a photo-condition step, and a stuck-payment banner that explains a failed transfer in plain words. The phase-70 scroll fix removes the last known irritation in the wizard: moving between steps now behaves like turning a page. The memberships page reads honestly to a non-specialist, with three kit-sized tiers, a persona strip, and a full per-item price list below, while the portal gives members live usage meters and one-tap perk booking.

The new Shoe Club presentation follows the same plain-words doctrine: one section inside the existing shoe-care area, three cards named by what you get (1, 3 or 5 pairs a month), per-pair arithmetic printed on the card, and a competitor anchor line that makes the value obvious without naming anyone. Club members see a dedicated card in the portal with its own usage meter, booking button and independent cancellation, and a shoes-only customer is still invited to explore laundry plans rather than hitting a dead end.

Findings

- P1 — delivery-day communication is email-only in production. The Termii sender configuration exists but the API key is not set, so there are no SMS or WhatsApp messages on pickup and delivery days, which is when customers actually look at their phones. Enabling the existing SMS path, or moving to the WhatsApp Business API, is the highest impact customer-facing change available.
- P2 — the invoice view is a rendered page rather than a downloadable PDF, which some corporate clients will ask for when invoicing through expense systems.

7 Commercial and Business Audit

Pricing and product ladder

The retail card is priced at the accessible end of the Lagos market (sneakers at 1,000 to 1,500 naira, shirts from 500, corporate laundry from 800 per kilogram), while the three membership tiers at 30,000, 50,000 and 80,000 naira a month are sized by physical kit volume, which keeps fulfilment honest. The Shoe Club extends the ladder downward with entry at 1,000 naira a month, which matters: the cheapest laundry plan is thirty times the price of the cheapest club month, so the club is the natural first product for a student or young professional who cannot yet commit to weekly laundry. Every number on every surface is

admin-editable at runtime, and price edits sync Paystack recurring plans when the keys are configured.

Competitive position (researched this session)

Lagos operator	Model	Observed pricing	Kozy answer
Care by Sneaklin	App-based sneaker laundry, 72h turnaround	Sneaker clean 8,000; leather 7,000; suede 12,000; premium packages 15,000-25,000 per pair	Shoe Club from 800-1,000 naira a pair with pickup and delivery included
LBN Laundry (Lekki)	Instagram-led cleaning and restoration	Around 10,000 naira per pair or pack	Standard sneaker clean at 1,000-1,500 naira a-la-carte
K-Kleen (Lekki)	Walk-in sneaker service with published list	Specialist per-pair pricing above laundry norms	Restoration from 5,000 with free assessment and quote-first approval

Table 1. Lagos shoe-care competitors researched 28 September 2026 versus the Kozy position.

The gap is large enough to be the marketing story rather than a fight over percentage points: Lagos sneaker laundries charge seven to eight thousand naira for a single basic clean, while the club lands between 800 and 1,000 naira per pair with collection and return included. Kozy can hold this position because shoes ride the existing rider routes and hub batches, which the dedicated specialists pay standalone logistics to replicate.

The demand gap

Everything commercial is built: plans, club, coupons with windows and caps, a calendar-synced newsletter engine, loyalty and referral ledgers, and Paystack recurring billing with transfer verification as the local fallback. Production currently shows zero memberships and a modest order book across two branches. The software cannot close that gap; only a sales motion can. The rider fleet itself is an underused channel: every delivery is a doorstep moment with a printed flyer in the bag, and the WhatsApp broadcast list built from order history is the cheapest acquisition channel available. The phase-69 rider response league now makes it possible to tie acquisition pushes to the riders who actually deliver on time.

Franchise readiness

The console now distinguishes company sites from partner sites end to end: gold treatment and partner chips, a revenue-share ledger through the Partners tab, and a numbers-reset that deliberately refuses franchise branches because their ledger is contractual. The expansion memo delivered in phase 69 remains the strategy document; the software side of a first franchise is ready, and the remaining work is contractual and operational rather than technical.

8 Data and Analytics

The reporting spine hardened considerably across phases 69 and 70. Every order is branch-attributed at creation, the historical book was backfilled to Chevron, response times from assignment to acceptance are captured for the rider league, and the new epoch reset lets the owner restart a company branch counters without touching financial records. Finance views filter by branch and date range, and Branch Health

surfaces the amber conditions that actually precede complaints: unrouted pickups, receipts waiting over twenty-four hours, and branches with no riders.

Findings

- P2 — there is no automated daily reconciliation between verified payments and the order book. The queues make manual verification reliable, but a scheduled report that totals verified payments per branch per day and emails exceptions would remove the last manual finance ritual.
- P2 — marketing analytics track opens and clicks but stop short of attribution to orders. Coupon codes partially close this; adding a campaign tag to the booking source would close it fully.

9 Prioritized Recommendations

The table below consolidates every finding from the preceding chapters into one ranked list. P0 items should be started this week, P1 within the month, and P2 items are scheduled work that improves life without protecting anything urgent.

#	Priority	Recommendation	Effort
1	P0	Run the sales motion: rider-delivered flyers with the Shoe Club offer, a WhatsApp broadcast to the order history, and a hotel/corporate push for per-kilogram laundry. The product is ready; distribution is not.	Ongoing
2	P0	Confirm rider push with two or three real riders this week (keys are now live): toggle notifications in the rider app Account tab, assign a stop, and verify the phone buzzes with the browser closed.	Half day
3	P1	Configure Upstash Redis (free tier) so booking, signup and payment rate limits hold across all serverless instances.	One hour
4	P1	Switch the production build from prisma db push --accept-data-loss to reviewed Prisma migrations, and rehearse a Supabase restore into a scratch database once, then monthly.	One day
5	P1	Enable SMS or WhatsApp delivery-day notifications (the Termii path is built; only the key is missing).	One hour plus review
6	P2	Stand up a staging deployment with a branched database for risky changes, and wire the existing E2E battery to run on deploy.	Two days
7	P2	Add an error tracker (free Sentry tier), dependency audit in CI, downloadable invoice PDFs, and rate limits on the remaining public trackers.	Scattered
8	P2	Introduce a weekly numbers ritual for the owner: Branch Health all-time lines, rider response league, and subscriber counts, fifteen minutes every Monday.	Habit

Table 2. Ranked recommendations from the audit.

10 The 30-60-90 View

The first thirty days belong to distribution and the two production-hardening items that guard it: the Redis rate limits and the migration switch. The Shoe Club launch is the marketing moment; the undercut against

dedicated sneaker laundries is so large that the story tells itself on any Lagos timeline, and the club entry price is low enough for impulse subscription. The rider fleet should carry the offer physically, and the newsletter engine should carry it digitally, with the Independence-week campaign already scheduled as the template.

Days thirty to sixty are the subscriber sprint. Concrete targets make the engine real: twenty-five Essentials households and fifteen Shoe Club members inside eight weeks would prove both funnels and generate the renewal data the admin screens are waiting for. The hotel and corporate channel deserves one dedicated push with the per-kilogram offer, because a single hotel contract out-earns dozens of retail members at zero incremental software cost. This is also the window for SMS or WhatsApp notifications, because delivery-day presence is what corporate clients remember.

Days sixty to ninety turn outward: the first franchise pilot using the ownership tooling that is now live, an evaluation of a third company site on the mainland using the branch health data as evidence, and a review of this audit with whatever the numbers say by then. The pattern across all three windows is the same one this audit found everywhere else: the platform keeps being ready slightly before the business needs it to be, which is exactly the order a young company wants those two things in.